정보시스템 진단

KOREA
코리아IT아카데미학원



class	정보보안 산업기사 취득과정 A
name	조채언

목 차

Ⅰ. 서버 취약점 항목 ····· 3
가. 유닉스(Unix) 서버 취약점 항목 ····· 3
나. 윈도(Windows) 서버 취약점 항목 ····· 4
다. 네트워크 취약점 항목 ····· 5
라. 애플리케이션 취약점 항목 ····· 6
마. DBMS 취약점 항목 ····· 7

Ⅱ. 정보시스템 진단 ····· 8
가. GRUB 접근 시 PASSWORD를 요구하도록 설정 ····· 8
나. 디렉토리 그룹 및 소유자 변경 없이 허가된 사용자만 접근하도록 설정 ····· 9
다. 패스워드 최대 사용기간 30일 설정 ····· 10
라. 패스워드 복잡도 설정 ····· 11
마. 이전 패스워드 5개 재사용 금지 설정 ····· 13

Ⅲ. 취약점 진단 및 대응 계획 ····· 15
가. SSH 접근 허용 설정 ····· 15
나. SSH 접근 제어 설정 ····· 17
다. 서버 파일 변조 여부 확인 ····· 19

Ⅳ. 세부 분석 항목별 취약점 진단 결과 ····· 23

Ⅰ. 서버 취약점 항목

가. 유닉스(Unix) 서버 취약점 항목

분류	취약점 점검 항목	등급
계정 관리	시스템 관리자(root) 계정 원격 접속 제한	상
	패스워드 복잡성 설정	상
	계정 잠금 임곗값 설정	상
	패스워드 파일 보호	상
	시스템 관리자(root) 이외의 UID(user identification number) '0' 금지	중
	시스템 관리자(root) 계정 전환(switch user) 제한	하
	패스워드 최소 길이 설정	중
	불필요한 계정 제거	하
	사용자 shell 점검	하
파일 및 디렉터리	시스템 관리자(root) 홈, 패스 디렉터리 권한 및 패스 설정	상
	파일 및 디렉터리 소유자 설정	상
	/etc/passwd 파일 소유자 및 권한 설정	상
	/etc/shadow 파일 소유자 및 권한 설정	상
	/etc/hosts 파일 소유자 및 권한 설정	상
	SUID(set user identification number), SGID(set group identification number), Sticky bit 설정 파일 점검	상
서비스 관리	Finger 서비스 비활성화	상
	Anonymous FTP 비활성화	상
	r 계열 서비스 비활성화	상
	ssh 원격 접속 허용	중

나. 윈도(Windows) 서버 취약점 항목

분류	취약점 점검 항목	등급
계정 관리	Administrator 계정 이름 바꾸기	상
	Guest 계정 상태	상
	불필요한 계정 제거	상
	계정 잠금 임곗값 설정	상
	해독 가능한 암호화를 사용하여 암호 저장	상
	관리자 그룹에 최소한의 사용자 포함	상
	Everyone 사용 권한을 익명 사용자에게 적용	중
서비스 관리	공유 권한 및 사용자 그룹 설정	상
	불필요한 서비스 제거	상
	IIS(Internet Information Services) 서비스 구동 점검	상
	IIS(Internet Information Services) 디렉터리 리스팅 제거	상
	IIS(Internet Information Services) CGI 실행 제한	상
	FTP 서비스 구동 점검	상
패치 관리	최신 HOT FIX 적용	상
	백신 프로그램 업데이트	상
보안 관리	화면 보호기 설정	상
	로그온하지 않고 시스템 종료 허용	상
	원격 시스템에서 강제로 시스템 종료	상

다. 네트워크 취약점 항목

분류	취약점 점검 항목	등급
네트워크 구조	Ping Sweep(ICMP Echo Request) 수행	중
	Broadcast ICMP 점검	중
	Non-ECHO ICMP 점검	중
	TCP Sweep 수행	상
	UDP Sweep 수행	상
포트 관리	TCP Connect Scan 수행	상
	Stealth Scan 수행	상
	Half-open SYN Scan 수행	상
	Inverse TCP Flag Scan 수행	중
	ACK Flag Probe Scan 수행	중
	TCP Fragmentation Scan 수행	중
네트워크 서비스	SNMP 서비스 사용 여부 및 설정 점검	상
	SNMP Community String(Default) 사용 여부	상
서비스 정보	애플리케이션 Banner 정보 수집	중
	배너 기반 버전 및 취약점 확인	상

라. 애플리케이션 취약점 항목

분류	취약점 점검 항목	등급
메모리 관리	버퍼 오버플로(Buffer Overflow) 여부 점검	상
	입력값 크기 검증 여부	상
	음수값(인덱스) 검증 여부	중
코드 보안	포맷스트링 삽입(Format String) 여부	상
	외부 입력값을 포맷 문자열로 사용하는지 점검	상
데이터 보호	중요 정보 평문 저장 여부	상
	중요 정보 암호화 저장 여부	상
변수 관리	초기화되지 않은 변수 사용 여부	중
	생성자를 통한 객체 변수 초기화 여부	중

마. DBMS 취약점 항목

분류	취약점 점검 항목	등급
계정 관리	기본 계정(Default Account) 사용 여부	상
	기본 패스워드 변경 여부	상
	빈 패스워드 계정 존재 여부	상
	localhost 및 127.0.0.1 계정 패스워드 설정 여부	상
패스워드 정책	패스워드 복잡성 정책 적용	상
	패스워드 변경 주기 설정	중
접근 통제	원격 DB 접속 제한 여부	상
	/etc/hosts.equiv 설정 점검	상
	Wildcard(%) 허용 여부	상
권한 관리	DBA 이외 시스템 테이블 접근 제한	상
감사 관리	DB 접근 감사 로그 설정	상
	데이터 변경·삭제 감사 로그 설정	상
패치 관리	최신 보안 패치 적용 여부	상
	정기적인 보안 패치 수행	중
	패치 작업 계획서 및 결과보고서 관리	중

Ⅱ. 정보시스템 진단

가. GRUB 접근 시 PASSWORD를 요구하도록 설정

1. GRUB 비밀번호 생성

```
root@roror:/etc/grub.d# grub2-setpassword
Enter password:
Confirm password:
root@roror:/etc/grub.d# cat /boot/grub2/user.cfg
GRUB2_PASSWORD=grub.pbkdf2.sha512.10000.92AC651583819CC40A1D3385B0A2C61B499294ED77708A909354E8C931B5EF8B3339C89
4677D2555F08907E6545663F595DA0854B0C5838E14CDF7EC4DA9053B.F897D773093A12A6883497E59C6AECAF022FA0A5E8E048CE3678F
12EEA03D413DA5490F1129BE0FFA5E7959B4074AFA881160799B13FB437F66B116A7D2D4BDF
```

grub2-setpassword 명령을 이용하여 GRUB 부트로더에 비밀번호를 설정하였으며, /boot/grub2/user.cfg 파일을 확인하여 암호화된 비밀번호가 정상적으로 저장된 것을 확인하였다.

2. 부팅 시 e를 눌러 비밀번호 입력



시스템 부팅 과정에서 e 키를 입력하여 GRUB 편집 모드에 접근을 시도한 결과, 설정한 비밀번호 입력을 요구하는 것을 확인하였다.

3. 비밀번호 입력 후 GRUB 편집 화면



비밀번호 인증에 성공한 후 GRUB 편집 화면이 정상적으로 표시되었으며, 커널 부팅 옵션을 수정할 수 있는 상태임을 확인하였다.

나. 디렉토리 그룹 및 소유자 변경 없이 허가된 사용자만 접근하도록 설정

1. backup 생성 후 권한 변경

```
root@roror:/# mkdir backup
root@roror:/# ls
afs     bin   data  etc   juice  lib64  media  opt   root  sbin  sys  usr
backup  boot  dev   home  lib    log    mnt    proc  run   srv   tmp  var
root@roror:/# ls -ld /backup
drwxr-xr-x. 2 root root 6 Jul 23 11:25 /backup
root@roror:/# chmod 750 /backup
root@roror:/# ls -ld /backup
drwxr-x---. 2 root root 6 Jul 23 11:25 /backup
```

/backup 디렉터리를 생성한 후 권한을 750으로 변경하여 소유자(root)는 읽기·쓰기·실행이 가능하고, 그룹은 읽기 및 실행만 가능하며, 기타 사용자의 접근은 차단되도록 설정하였다. 이를 통해 허가되지 않은 사용자의 접근을 제한하였다.

2. ACL을 이용한 특정 사용자 접근 허용

```
root@roror:/# setfacl -m u:roror:rwx /backup
root@roror:/# getfacl /backup
getfacl: Removing leading '/' from absolute path names
# file: backup
# owner: root
# group: root
user::rwx
user:roror:rwx
group::r-x
mask::rwx
other::---
```

setfacl 명령을 사용하여 roror 사용자에게 /backup 디렉터리에 대한 rwx 권한을 부여하였다. getfacl 명령으로 ACL이 정상적으로 적용되어 지정된 사용자만 추가 접근 권한을 가지는 것을 확인하였다.

3. 허용 계정 접근 권한 확인

```
root@roror:/# su - roror
Last login: Thu Jul 23 11:40:33 KST 2026 on pts/1
roror@roror:~$ cd /backup/
roror@roror:/backup$ touch test
roror@roror:/backup$ ls
test
```

허용한 계정으로 접속을 하여 /backup 디렉터리에 접근하여 파일을 생성하였다.

4. 비허용 계정 접근 권한 확인

```
root@roror:/home# su - test
test@roror:~$ cd /backup
-bash: cd: /backup: Permission denied
test@roror:~$ cd /
test@roror:/$ ls
afs     bin   data  etc   initrd  lib64  media  opt   root  sbin  sys  usr
backup  boot  dev   home  lib     log    mnt    proc  run   srv   tmp  var
test@roror:/$ cd backup
-bash: cd: backup: Permission denied
```

비허용한 계정으로 접속을 하여 /backup 디렉터리에 접근하니 Permission denied 이 출력되었다.
권한이 없는 사용자의 접근이 정상적으로 차단되는 것을 확인하였다.

다. 패스워드 최대 사용기간 30일 설정

1. 패스워드 최대 사용기간 변경

```
root@roror:/home/roror# awk -F: '$3 >= 1000 && $1 != "nobody" {print $1}' /etc/p
asswd | while read user; do chage -M 30 "$user"; done
```

- awk -F: : /etc/passwd 파일을 : 기준으로 읽음
- $3 >= 1000 : UID가 1000 이상인 일반 사용자만 선택
- $1 != "nobody" : nobody 계정은 제외
- print $1 : 조건에 맞는 사용자의 계정명만 출력
- while read user; do : 사용자명을 한 줄씩 읽어 user 변수에 저장하며 반복 수행
- chage -M 30 : 해당 사용자의 비밀번호 최대 사용기간을 30일로 설정
- done : 모든 일반 사용자에 대해 반복 작업 종료

2. roror 계정 최대 사용기간 확인

```
root@roror:/home/roror# chage -l roror
Last password change                                    : never
Password expires                                        : never
Password inactive                                       : never
Account expires                                         : never
Minimum number of days between password change          : 0
Maximum number of days between password change          : 30
Number of days of warning before password expires       : 7
```

roror 계정의 최대 사용기간을 확인해 보면 30으로 정상적으로 바뀐 것을 확인하였다.

라. 패스워드 복잡도 설정

1. pwquality 사용해 패스워드 정책 설정

```
# vi /etc/security/pwquality.conf
# Minimum acceptable size for the new password (plus one if
# credits are not disabled which is the default). (See pam_cracklib manual.)
# Cannot be set to lower value than 6.
minlen = 8
#
# The maximum credit for having digits in the new password. If less than 0
# it is the minimum number of digits in the new password.
dcredit = -1
#
# The maximum credit for having uppercase characters in the new password.
# If less than 0 it is the minimum number of uppercase characters in the new
# password.
ucredit = -1
#
# The maximum credit for having lowercase characters in the new password.
# If less than 0 it is the minimum number of lowercase characters in the new
# password.
lcredit = -1
#
# The maximum credit for having other characters in the new password.
# If less than 0 it is the minimum number of other characters in the new
# password.
ocredit = -1
#
# The minimum number of required classes of characters for the new
# password (digits, uppercase, lowercase, others).
# minclass = 0
#
# The maximum number of allowed consecutive same characters in the new password.
# The check is disabled if the value is 0.
maxrepeat = 2
```

- minlen = 8 : 최소 패스워드 길이
- ucredit = -1 : 대문자 최소 1개 이상
- lcredit = -1 : 소문자 최소 1개 이상
- dcredit = -1 : 숫자 최소 1개 이상
- ocredit = -1 : 특수문자 최소 1개 이상
- maxrepeat = 2 : 동일한 문자의 연속 반복 최대 2개까지 허용

2. 패스워드 테스트

```
roror@roror:~$ passwd
Current password:
New password:
BAD PASSWORD: The password is the same as the old one
passwd: Authentication token manipulation error
passwd: password unchanged
```

패스워드를 간단한 비밀번호(1111)을 입력하였더니 패스워드 정책에 따라 패스워드 변경 에러가 나며 비밀번호 변경 처리가 취소되었다.

※ root는 기본적으로 비밀번호 정책을 강제로 우회할 수 있으니 일반 사용자(roror)로 테스트해야 한다.

마. 이전 패스워드 5개 재사용 금지 설정

1. PAM 규칙 변경

vi /etc/pam.d/system-auth

```
password    requisite     pam_pwquality.so
password    required      pam_pwhistory.so remember=5 use_authtok
password    sufficient    pam_unix.so yescrypt shadow nullok use_authtok
password    required      pam_deny.so
```

비밀번호 변경 시 최근 5개의 비밀번호를 기억하여 재사용을 금지하고, 이전 PAM 모듈에서 입력받은 비밀번호를 이용해 정책을 적용하도록 설정한다.

2. 규칙 적용

```
root@roror:/home/roror# authselect enable-feature with-pwhistory
root@roror:/home/roror# authselect apply-changes
Changes were successfully applied.
```

- authselect enable-feature with-pwhistory : 시스템 인증 프레임워크(PAM) 설정 프로필에 비밀번호 이력 관리 기능(pam_pwhistory)을 사용하도록 지정한다.
- authselect apply-changes : 활성화된 인증 기능 및 설정 옵션을 실제 시스템 인증 구성 파일(/etc/pam.d/)에 즉시 반영 및 적용한다.

3. 비밀번호 재사용 제한 수치 설정

vi /etc/security/pwhistory.conf

```
# Configuration for remembering the last passwords used by a user.
#
# Enable the debugging logs.
# Enabled if option is present.
# debug
#
# root account's passwords are also remembered.
# Enabled if option is present.
# enforce_for_root
#
# Number of passwords to remember.
# The default is 10.
remember = 5
#
# Number of times to prompt for the password.
# The default is 1.
# retry = 1
#
# The file where the last passwords are kept.
# The default is /etc/security/opasswd.
# file = /etc/security/opasswd
```

비밀번호 이력 관리 설정 파일을 수정하여 최근 사용한 비밀번호의 재사용 금지 개수를 설정합니다. remember = 5 옵션을 적용하여 이전 비밀번호 5개 항목에 대한 재사용을 제한함으로써 계정 보안을 강화한다.

4. 패스워드 제한 설정 확인

```
test@roror:~$ passwd
Current password:
New password:
Retype new password:
Password has been already used. Choose another.
passwd: Have exhausted maximum number of retries for service
passwd: password unchanged
```

패스워드를 한 번 바꾼 후 다시 처음에 했던 패스워드로 다시 설정하니 이미 했던 비밀번호라 다른 비밀번호로 설정하라는 명령어가 출력된다.

Ⅲ. 취약점 진단 및 대응 계획

가. SSH 접근 허용 설정

1. SSH 접근 허용 사용자 설정

vi /etc/ssh/sshd_config

```
AllowUsers roror
```

```
root@roror:/home# systemctl restart sshd
```

SSH 설정 파일에 AllowUsers roror 구문을 추가하여 특정 사용자만 SSH 접속이 가능하도록 제한하고, 변경된 설정을 적용하기 위해 sshd 서비스를 재시작합니다.

2. 허용된 계정 SSH 접속 테스트

```
root@roror:/home# ssh roror@localhost
The authenticity of host 'localhost (::1)' can't be established.
ED25519 key fingerprint is SHA256:nNucPHCnymF/gr/mTnNaDe+elct1PlxrJhnFai8kNI4.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'localhost' (ED25519) to the list of known hosts.
Welcome
roror@localhost's password:
Welcome Test Motd
Web console: https://roror.co.kr:9090/ or https://10.0.0.200:9090/

Last login: Thu Jul 23 14:19:07 2026
```

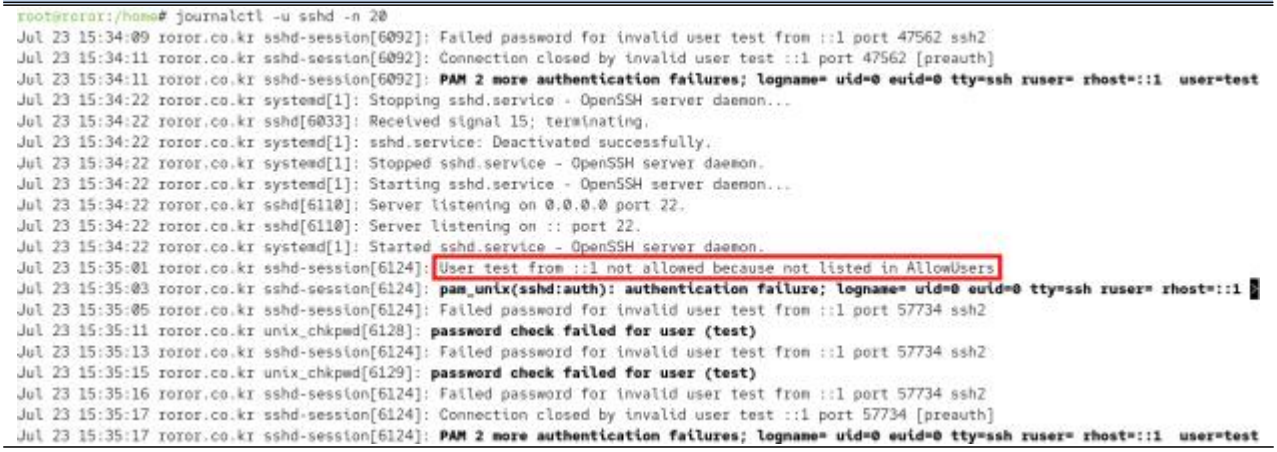
SSH 접근이 허용된 roror 계정으로 로컬호스트 접속을 시도하여 정상적으로 패스워드 인증을 마치고 로그인에 성공함을 확인한다.

3. 미허용 계정 SSH 접속 테스트

```
roror@roror:~$ ssh test@localhost
The authenticity of host 'localhost (::1)' can't be established.
ED25519 key fingerprint is SHA256:nNucPHCnymF/gr/mTnNaDe+elct1PlxrJhnFai8kNI4.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'localhost' (ED25519) to the list of known hosts.
Welcome
test@localhost's password:
Permission denied, please try again.
```

SSH 접근 권한이 부여되지 않은 test 계정으로 접속을 시도하여 Permission denied 에러와 함께 로그인 접속이 정상적으로 차단된다.

4. SSH 서비스 감사 로그 확인



SSH 로그를 조회하여 User test ... not allowed because not listed in AllowUsers 메시지를 통해 미허용 계정의 접속 차단 사유를 명확히 확인한다.

취약점 진단	현재 SSH 서비스는 모든 일반 계정의 원격 접속이 가능하여 허가되지 않은 사용자가 서버에 접근을 시도할 수 있는 상태이다. 이 경우 무차별 대입 공격(Brute Force Attack), 계정 탈취, 내부 사용자에 의한 불필요한 원격 접속 등 보안 위험이 증가할 수 있다.
대응 계획	/etc/ssh/sshd_config 파일의 AllowUsers 옵션을 이용하여 허가된 사용자(roror)만 SSH 접속을 허용하도록 설정하고, SSH 서비스를 재시작하여 정책을 적용한다.
보안 효과	허가된 사용자만 원격 접속할 수 있도록 제한함으로써 공격 대상이 되는 계정을 최소화하고, 비인가 사용자의 접근을 차단하여 원격 침입 가능성을 감소시키기 위함이다. 또한 계정 탈취가 발생하더라도 허가되지 않은 계정으로는 SSH 접속이 불가능하여 피해를 줄일 수 있다.

나. SSH 접근 제어 설정

1. SFTP Chroot 설정

vi /etc/ssh/sshd_config

```
Match User roror
    ChrootDirectory /home/roror
    ForceCommand internal-sftp
    AllowTcpForwarding no
    X11Forwarding no
```

SSH 설정 파일을 수정하여 roror 사용자의 접속 환경을 SFTP 전용(ForceCommand internal-sftp)으로 제한하고, 최상위 경로를 홈 디렉토리로 격리(ChrootDirectory /home/roror)하며 Port/X11 포워딩을 차단한다.

2. Chroot 루트 디렉토리 소유권 및 권한 변경

```
root@roror:/home/roror# chown root:root /home/roror
root@roror:/home/roror# chmod 755 /home/roror
```

OpenSSH Chroot 필수 보안 요구사항을 충족하기 위해 /home/roror 디렉토리의 소유자를 root:root로 변경하고 권한을 755로 설정합니다.

3. 사용자 업로드용 디렉토리 생성

```
root@roror:/home/roror# mkdir /home/roror/files
root@roror:/home/roror# chown roror:roror /home/roror/files
root@roror:/home/roror# systemctl restart sshd
```

Chroot 설정 후 사용자가 파일 업로드 작업을 수행할 수 있도록 하위 디렉토리(files)를 생성하여 권한을 부여한 뒤, sshd 서비스를 재시작하여 변경사항을 적용한다.

4. SFTP 접속 후 디렉토리 접근 차단

```
kali@kali:~$ sftp roror@10.0.0.200
Welcome
roror@10.0.0.200's password:
Connected to 10.0.0.200.
sftp> ls
Desktop                 Documents               Downloads               Maildir
Music                   Pictures                Public                  Templates
Videos                  backup                  bwapp.tar               certs
docker                  files                   fork_test               git
html5-css3-master.zip   httpd-2.4.66.tar        insecure.zip            juice
juice-shop_20.1.1       main(pentest).zip       public_html             signal
test.txt                today                   zombi
sftp> cd /etc
stat remote: No such file or directory
```

외부 클라이언트에서 SFTP로 접속하여 로그인에 성공한 후, /etc 등 다른 디렉토리로 이동 시도 시 No such file or directory 에러가 발생한다.

취약점 진단	일반 사용자가 SSH로 접속한 후 시스템 전체 디렉터리에 접근할 수 있는 경우, 중요 시스템 파일을 열람하거나 설정 파일을 변경할 가능성이 존재한다.
대응 계획	사용자를 홈 디렉터리로 제한하는 접근 제어 정책(Chroot 또는 SFTP 기반 접근 제한)을 적용하여 허가된 작업 영역 외에는 접근하지 못하도록 설정한다.
보안 효과	사용자가 필요한 작업 공간에서만 작업하도록 제한하여 시스템 파일의 기밀성과 무결성을 보호하기 위함이다. 또한 계정이 탈취되더라도 공격자의 활동 범위를 홈 디렉터리 내부로 제한하여 침해 범위를 최소화할 수 있다.

다. 서버 파일 변조 여부 확인

1. Tripwire 설치

```
root@roror:/home/roror# dnf install tripwire
Rocky Linux 10 - BaseOS                                  4.8 kB/s | 4.3 kB     00:00
Rocky Linux 10 - BaseOS                                  8.2 MB/s |  11 MB     00:01
Rocky Linux 10 - BaseOS - Debug                          3.6 kB/s | 3.0 kB     00:00
Rocky Linux 10 - BaseOS - Debug          [               ---                ] ---  B/s |   0  B     --:-- ETA
```

Tripwire 패키지를 설치하여 시스템 파일의 무결성을 점검할 수 있는 환경을 구성한다.

2. Tripwire 키 파일 생성

```
root@roror:/etc/tripwire# tripwire-setup-keyfiles

-----------------------------------------------
The Tripwire site and local passphrases are used to sign a  variety  of
files, such as the configuration, policy, and database files.

Passphrases should be at least 8 characters in length and contain  both
letters and numbers.

See the Tripwire manual for more information.

-----------------------------------------------
Creating key files...

(When selecting a passphrase, keep in mind that good passphrases typically
have upper and lower case letters, digits and punctuation marks, and are
at least 8 characters in length.)

Enter the site keyfile passphrase:
Verify the site keyfile passphrase:
Generating key (this may take several minutes)...Key generation complete.
```

Site Key와 Local Key를 생성하여 Tripwire의 설정 파일과 무결성 데이터베이스를 안전하게 관리할 수 있도록 한다.

3. 설정 파일 서명

```
root@roror:/etc/tripwire# twadmin -m F -c tw.cfg -S site.key twcfg.txt
Please enter your site passphrase:
Wrote configuration file: /etc/tripwire/tw.cfg
```

twcfg.txt 설정 파일을 Site Key로 서명하여 무결성과 신뢰성이 보장되도록 서명된 설정 파일 tw.cfg 생성한다.

4. 정책 파일 서명

```
root@roror:/etc/tripwire# twadmin -m P -S site.key twpol.txt
Please enter your site passphrase:
Wrote policy file: /etc/tripwire/tw.pol
```

Tripwire 정책 파일을 Site Key로 서명하여 시스템 무결성에 사용할 검사 정책을 적용한다.

5. 초기 데이터베이스 생성

```
root@roror:/etc/tripwire# tripwire --init
Please enter your local passphrase:
Parsing policy file: /etc/tripwire/tw.pol
Generating the database...
*** Processing Unix File System ***
### Warning: File system error.
### Filename: /usr/sbin/fixrmtab
### No such file or directory
### Continuing...
```

현재 시스템 파일의 해시값과 속성을 기준으로 초기 무결성 데이터베이스를 생성한다.
기준 데이터베이스가 생성되어 이후 파일의 변경 여부를 비교할 수 있는 기준 정보가 마련되었다.

6. 무결성 검사 수행

```
root@roror:/etc/tripwire# tripwire --check
Parsing policy file: /etc/tripwire/tw.pol
*** Processing Unix File System ***
Performing integrity check...
### Warning: File system error.
### Filename: /usr/sbin/fixrmtab
### No such file or directory
### Continuing...
### Warning: File system error.
### Filename: /usr/share/grub/i386-redhat/e2fs_stage1_5
### No such file or directory
### Continuing...
```

현재 시스템의 파일 정보를 초기 데이터베이스와 비교하여 파일의 변경 여부를 검사한다. 무결성 검사가 정상적으로 완료되었으며 변경, 추가, 삭제된 파일을 탐지할 수 있는 보고서가 생성되었다.

7. 검사 결과 확인

```
root@roror:/var/lib/tripwire/report# ls
roror.co.kr-20260724-091742.twr
root@roror:/var/lib/tripwire/report# twprint -m r -r ./roror.co.kr-20260724-091742.twr
Note: Report is not encrypted.
Open Source Tripwire(R) 2.4.3.7 Integrity Check Report

Report generated by:          root
Report created on:            Fri 24 Jul 2026 09:17:42 AM KST
Database last updated on:     Never

===============================================================================
Report Summary:
===============================================================================

Host name:                    roror.co.kr
Host IP address:              10.0.0.200
Host ID:                      None
Policy file used:             /etc/tripwire/tw.pol
Configuration file used:      /etc/tripwire/tw.cfg
Database file used:           /var/lib/tripwire/roror.co.kr.twd
Command line used:            tripwire --check

===============================================================================
Rule Summary:
===============================================================================
```

Tripwire 기반 무결성 점검 결과 총 57,502개의 시스템 객체를 검사하였으며, 2건의 변경 사항이 탐지되었다.

첫 번째 탐지 항목인 /usr/lib/sysimage/rpm/rpmdb.sqlite-shm 파일 변경은 RPM 데이터베이스 관련 정상적인 시스템 동작 과정에서 발생한 것으로 판단된다.

두 번째 탐지 항목인 /var/lib/tripwire/roror.co.kr.twd 파일 추가는 Tripwire 데이터베이스 초기 생성 과정에서 발생한 정상 이벤트이다.

따라서 현재 서버 상태는 심각한 무결성 침해 징후는 발견되지 않은 정상 범위로 판단되며, 향후 안정적인 점검을 위해 운영체제 환경에 맞는 Tripwire 정책 재작성 및 정상 기준 데이터베이스 재생성이 필요하다.

8. 변경된 파일 경로 확인

```
root@roror:/var/lib/tripwire/report# twprint -m r -r ./roror.co.kr-20260724-091742.twr | grep "Modified object name" |
 awk -F: '{print $2}'
  /usr/lib/sysimage/rpm/rpmdb.sqlite-shm
```

grep 명령을 이용하여 Tripwire 검사 결과 중 Modified object name 항목만 검색하고, awk를 이용하여 변경된 파일의 경로만 추출하였다.

변경된 파일의 경로를 /usr/lib/sysimage/rpm/rpmdb.sqlite-shm으로 확인하였으며, 무결성 검사 과정에서 변경된 파일을 식별할 수 있음을 확인하였다.

9. 변경된 파일 출력 형식 변경

```
root@roror:/var/lib/tripwire/report# twprint -m r -r ./roror.co.kr-20260724-091742.twr | grep 'Modified object name' |
 awk -F: '{print "변경된 파일 및 디렉토리: " $2}'
변경된 파일 및 디렉토리:   /usr/lib/sysimage/rpm/rpmdb.sqlite-shm
```

awk를 이용하여 출력 형식을 변경하고, 변경된 파일의 경로 앞에 "변경된 파일 및 디렉토리:"라는 문구를 추가하여 결과를 보기 쉽게 출력하였다.
변경된 파일 및 디렉터리를 /usr/lib/sysimage/rpm/rpmdb.sqlite-shm으로 확인하였으며, Tripwire 보고서에서 필요한 정보만 추출하여 효율적으로 확인할 수 있었다.

취약점 진단	서버가 침해될 경우 시스템 파일이나 설정 파일이 악성코드에 의해 변조될 수 있으며, 관리자가 이를 즉시 인지하지 못하면 추가적인 공격이나 정보 유출로 이어질 수 있다.
대응 계획	Tripwire를 이용하여 시스템 파일의 해시값과 속성을 초기 데이터베이스에 저장하고, 주기적으로 현재 파일과 비교하여 변경·추가·삭제된 파일을 탐지하도록 한다.
보안 효과	파일의 무결성(Integrity) 을 지속적으로 검증하여 시스템 파일 변조를 신속하게 탐지하고, 침해사고 발생 시 변경된 파일을 빠르게 식별하여 사고 대응 및 원인 분석을 용이하게 하기 위함이다. 또한 악성코드나 비인가 변경을 조기에 발견하여 피해 확산을 방지할 수 있다.

Ⅳ. 세부 분석 항목별 취약점 진단 결과

점검 분야	분석 항목	위험도	빈도수	점검 결과
서버	시스템 관리자(root) 계정 원격 접속 제한	상	1	양호
	패스워드 복잡성 설정	상	1	양호
	계정 잠금 임계값 설정	상	1	양호
	패스워드 파일 보호	상	1	양호
	시스템 관리자(root) 이외의 UID(user identification number)가 '0' 금지	중	1	양호
네트워크	vty(Virtual Teletype) 접근(ACL) 설정	하	1	양호
	Session Timeout 설정	중	1	양호
	vty(Virtual Teletype) 접속 시 안전한 프로토콜 사용	하	1	양호
	불필요한 보조 입출력 포트 사용 금지	하	1	양호
데이터베이스	데이터베이스 관리자 권한을 꼭 필요한 계정 및 그룹에 대해서만 허용	상	1	양호
	패스워드 재사용에 대한 제약이 설정되어 있는가	상	1	양호
	원격에서 데이터베이스 서버로의 접속 제한	상	1	양호
	DBA(DataBase Administrator) 이외의 인가되지 않은 사용자가 시스템 테이블에 접근할 수 없도록 설정	중	1	양호

1. 시스템 관리자(root) 계정 원격 접속 제한

초기 점검 결과 SSH 서비스에서 원격 접속 가능한 사용자에 대한 제한이 설정되어 있지 않아, 허가되지 않은 일반 계정도 관리자 계정으로의 원격 접속을 시도할 수 있는 상태였다. 이러한 환경에서는 무차별 대입 공격이나 계정 탈취 시도를 통한 시스템 침해 위험이 증가할 수 있다. 이를 방지하기 위해 /etc/ssh/sshd_config 파일의 AllowUsers 옵션을 사용하여 허가된 사용자(roror)만 SSH 접속이 가능하도록 설정하고, SSH 서비스를 재시작하여 정책을 적용하였다. 이후 허가되지 않은 계정으로 SSH 접속을 시도한 결과 User test not allowed because not listed in AllowUsers 메시지가 출력되며 접속이 차단되는 것을 확인하였다. 이를 통해 허가된 사용자만 원격 접속이 가능하도록 접근 통제가 정상적으로 적용되었으며, 관리자 계정 원격 접속 제한 항목은 양호로 판단하였다.

2. 패스워드 복잡성 설정

점검 결과 초기에는 단순하거나 추측하기 쉬운 패스워드를 사용할 수 있는 상태로, 사전 공격 및 무차별 대입 공격에 취약한 것으로 확인되었다. 이에 패스워드에 대문자, 소문자, 숫자 및 특수문자를 각각 최소 1개 이상 포함하도록 설정하고, 연속되거나 반복되는 단순 문자열의 사용을 제한하였다. 또한 최소 길이 및 복잡도 정책을 적용하여 안전한 비밀번호만 사용할 수 있도록 구성하였다. 설정 후 passwd 명령으로 단순 비밀번호를 입력하여 테스트한 결과 BAD PASSWORD 경고 메시지가 출력되는 것을 확인하였으며, 복잡한 비밀번호는 정상적으로 변경되는 것을 확인하였다. 이를 통해 패스워드 복잡성 정책이 정상적으로 적용되어 계정 보안 수준이 향상되었으며, 해당 항목은 양호로 평가하였다.